LORDS
Institute of Engineering & Technology
MUSLIM MINORITY INSTITUTION
(UGC Autonomous Institution)
Accredited by NBA, Accredited 'A' Grade by NAAC

Department of Computer Science and Engineering

AI Data Leakage Detection & Prevention System

Project Review – 1

Presented By:

Syed Misbah Uddin Haseeb – 160923733208

Sheak Sumear – 160923733324

Mohd Arsalaan – 160923722184

Omar Aslam – 160923733236

Under the Guidance of

Ms. Koyeti Priyarika Sagar, Assistant Professor

Contents

1 Aim & Objective

2 Abstract

3 Introduction & Problem

4 Literature Review

5 Research Gap

6 System Analysis

7 System Requirements

8 System Design

9 Implementation

10 Results & Work Plan

Aim & Objective

LORDS Institute of Engineering & Technology
MUSLIM MINORITY INSTITUTION
(UGC Autonomous Institution)
Accredited by NBA, Accredited 'A' Grade by NAAC

AIM

To design a real-time system that detects and prevents sensitive-data leakage in AI interactions.

Objectives

- Intercept every prompt and response in real time
- Detect PII, secrets and code with hybrid NLP
- Cover Indian IDs: Aadhaar, PAN, UPI, IFSC
- Score risk, then allow, mask, block or alert
- Keep audit logs that support DPDP compliance

Abstract

- Employees paste code, credentials and customer data into AI tools
- Rule-based DLP misses context in natural-language prompts
- We propose a middleware that inspects every prompt and response
- Hybrid detection: regex + checksum, NER and a transformer classifier
- A 0–100 risk score decides: allow, mask, block or alert
- Dashboard and audit logs support DPDP Act compliance



Introduction

- Generative AI is now part of everyday enterprise work
- Convenience hides risk: a prompt can carry confidential data
- Once data reaches a public AI tool, the organization loses control

579,113

sensitive-data exposures found in 22.4 million enterprise prompts

665

different generative-AI tools seen in the same dataset

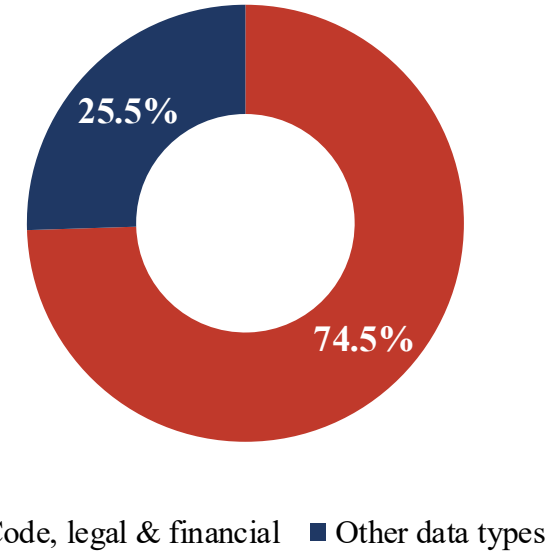
$4.74M

average breach cost with high shadow AI (vs $4.07M)

Sources: Harmonic Security, analysis of 2025 enterprise prompts (Jan 2026) [11]; IBM Cost of a Data Breach Report 2025 [13]

Problem Statement

- Confidential data is pasted into public AI tools
- Prompts may be stored, logged or reused
- Firewalls and rule-based DLP cannot read context
- Shadow AI tools are invisible to IT teams
- Indian IDs (Aadhaar, PAN, UPI) are often missed by global tools



Exposed content by type (Harmonic Security, 2025 data) [11]

17%

of exposures came from free or personal AI accounts, outside IT visibility [11]

Literature Review (1/4)

Guardrails and monitoring for AI interactions

Reference	Contribution	Limitation / Gap
SafeGPT Desai et al., 2026 [1]	Two-sided guardrail for enterprise LLMs: input redaction, output moderation and human feedback; staged regex, NER and semantic matching.	Built for generic enterprise text; Indian identifiers, risk-scored actions and compliance reporting are not its focus.
LeakSealer Panebianco et al., 2025 [2]	Semi-supervised defense that maps past interactions; PII-leak detection reaches AUPRC 0.97 and beats Llama Guard.	Learns from interaction history and centres on detection; masking prompts before submission is not its focus.
Safety Nudges arXiv, 2026 [3]	Browser extension that audits chatbot conversations in real time, without provider cooperation, and nudges users about risk.	Awareness-oriented; an enterprise policy engine, redaction and audit reporting are not its focus.
AI-DLP tools LayerX, Nightfall, Strac, 2026	Commercial browser extensions inspect pastes, prompts and uploads and discover shadow-AI tools.	Proprietary, so detection accuracy cannot be independently verified; Indian-ID support is unclear.

Literature Review (2/4)

PII detection and prompt sanitization

Reference	Contribution	Limitation / Gap
RECAP Rajgarhia et al., 2025 [4]	Regex plus context-aware LLM across 13 low-resource locales and 300+ entity types; beats fine-tuned NER by 82% (weighted F1).	A detection module only; not tied to live prompt interception, risk scoring or prevention.
Light-weight LMs for PII masking arXiv, 2025 [5]	Fine-tuned Mistral 7B reaches 0.962 label-exact precision and was tested on real chat text.	Real-time use shows an accuracy versus latency trade-off; a 7B model is heavy.
Data Minimization for LLM Prompting arXiv, 2025 [6]	Searches for the most-redacted prompt that keeps answer quality: 85.7% redaction with GPT-5, 19.3% with a small model.	Results depend on the response model; small local models tolerate far less redaction.
SurrogateShield arXiv, 2026 [7]	Replaces PII with surrogates instead of placeholders for better utility; all detection runs locally.	Focuses on PII substitution; risk scoring, policy actions and audit dashboard are not its focus.

Literature Review (3/4)

Attacks, leakage studies and shadow AI

Reference	Contribution	Limitation / Gap
Multi-Stage Prompt Inference arXiv, 2025 [8]	Chained harmless-looking prompts extract data from enterprise LLMs; proposes anomaly detection, access control, sanitization.	Threat-model and simulation study; no deployable end-user prevention tool.
Prompt Leaking in Real Apps arXiv, 2026 [9]	Large-scale study: prompt leakage is widespread; existing defenses struggle to balance protection and usability.	Protects an application's system prompt, not employee data flowing out to AI tools.
ISACL arXiv, 2025 [10]	Reads the model's internal state to flag training-data leakage before decoding.	Needs access to model internals, so it cannot protect third-party chatbots.
Shadow AI Apps note Cloud Security Alliance, 2026 [12]	Reports that 77% of employees paste data into genAI and 82% of that comes from unmanaged accounts (LayerX data).	Governance analysis; proposes no technical detection method.

Literature Review (4/4)

Agentic systems and multi-agent leakage (2026)

Reference	Contribution	Limitation / Gap
Agent Mosaic Ruiz et al., 2026 [17]	Agents combine harmless document fragments into forbidden conclusions; unsafe disclosures persisted in 32.37% of answers even with safeguards.	Measurement study on synthetic scenarios; offers no detector for employee prompts leaving the organization.
Multi-Agent Firewall García Cuesta et al., 2026 [18]	Open-source firewall: browser extension plus proxy, tiered detection from rules to NER and LLM checks; F1 up to 94.93%. Closest to our work.	Aimed at individual users and outbound prompts; response monitoring is future work; enterprise policy, audit and Indian IDs are not its focus.
PRISM Tapwal et al., 2026 [19]	Generation-time defence for secrets in multi-agent pipelines: 16 signals give a risk score with green / yellow / red zones; F1 0.832.	Targets credential leakage inside agent pipelines; recall is 0.712; PII and Indian IDs are not its focus.
You Told Me to Do It Kao et al., 2026 [20]	README-embedded instructions make high-privilege agents leak local files; 12 rule-based and 6 LLM-based detectors were not reliable.	Attack measurement on installation agents; not a prevention system for enterprise prompts.

Research Gap

What the surveyed 2025–2026 work still leaves open

G1

Fragmented defences

Each work protects one path: prompt PII [4], system prompts [9], training data [10], multi-turn attacks [8] or agent pipelines [17][19][20].

G2

Accuracy vs. latency trade-off

Accurate LLM-based redaction is heavy [5][6]; tiered designs exist [18] but target individual users, not enterprises.

G3

Indian context is missing

No surveyed paper evaluates Aadhaar, PAN, UPI or Hinglish text; only open-source tools try [14][15].

G4

Detection without graded action

Graded risk zones exist for agent secrets [19]; few map prompt-level scores to policy actions with an audit trail [1][2].

G5

Little real-time evidence

End-to-end latency on live prompt flow is rarely reported; the trade-off is noted in [5].

Gap analysis is based on the abstracts and methods of the surveyed papers.

Our Contribution

How this project goes beyond existing work

G1 Fragmented defences	One pipeline covering prompt, response, audit log and dashboard
G2 Accuracy vs. latency trade-off	Enterprise-tuned tiers (fast regex first, transformer only when needed) with a latency budget, extending the idea in [18]
G3 Indian context is missing	Indian-ID detectors (Aadhaar with Verhoeff checksum, PAN, UPI, IFSC) and a Hinglish test set
G4 Detection without graded action	Prompt-level risk score 0–100 mapped to allow, mask, block or alert, with explainable audit logs
G5 Little real-time evidence	Measured precision, recall, F1 and latency against Presidio and regex-only baselines

System Analysis

LORDS Institute of Engineering & Technology
MUSLIM MINORITY INSTITUTION
(UGC Autonomous Institution)
Accredited by NBA, Accredited 'A' Grade by NAAC

Existing System

- Rule-based DLP and regex only
- Cannot read the context of AI prompts
- Blind to shadow AI tools
- Finds leaks after the damage

Proposed System

- Hybrid regex + NER + transformer
- Inspects prompts and responses
- Discovers and logs AI tool use
- Masks or blocks before sending

System Requirements

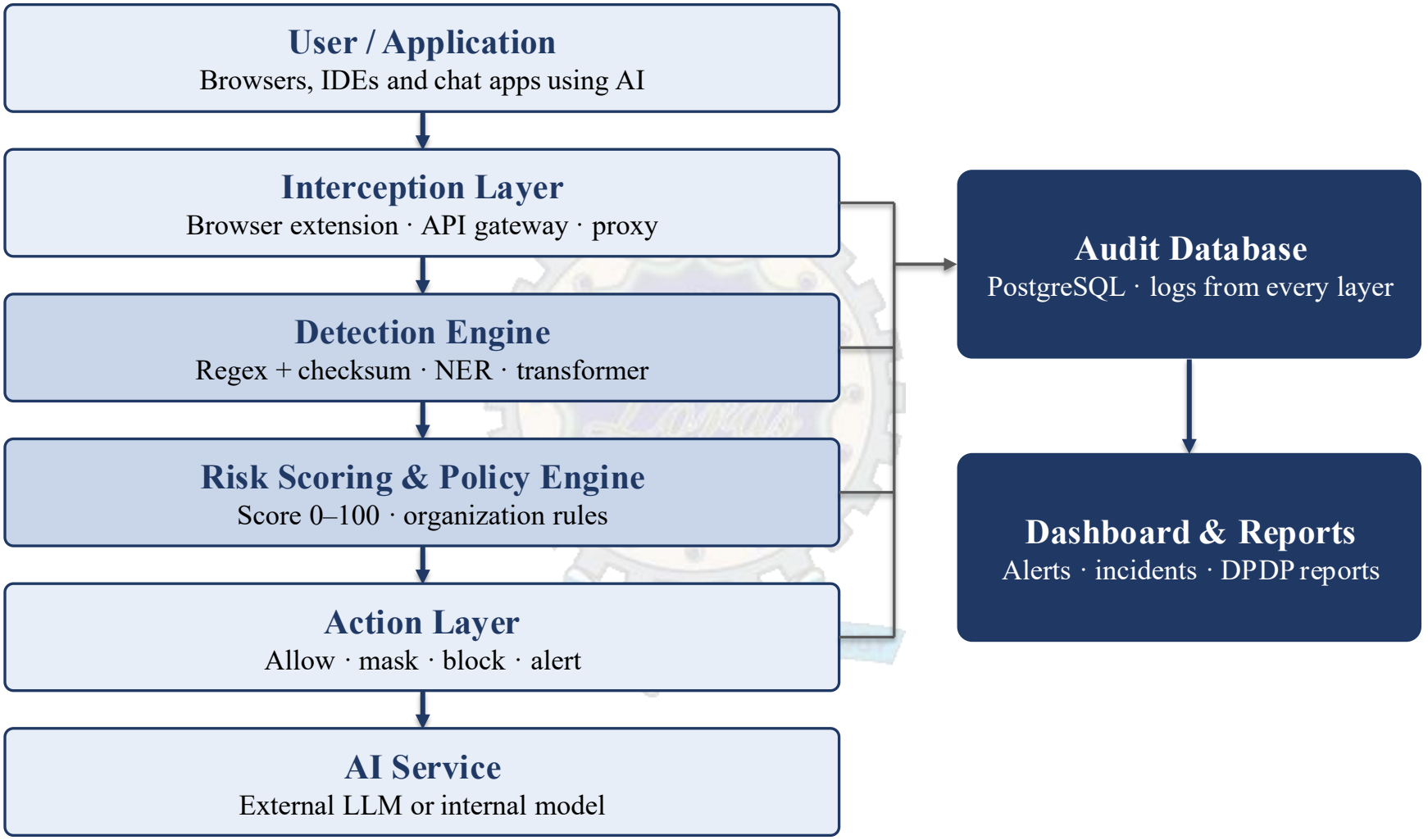
Hardware

- Processor: Core i5 or Ryzen 5 and above
- RAM: 16 GB (8 GB minimum)
- Storage: 256 GB SSD
- GPU: optional, for model fine-tuning
- Internet: for AI service APIs

Software

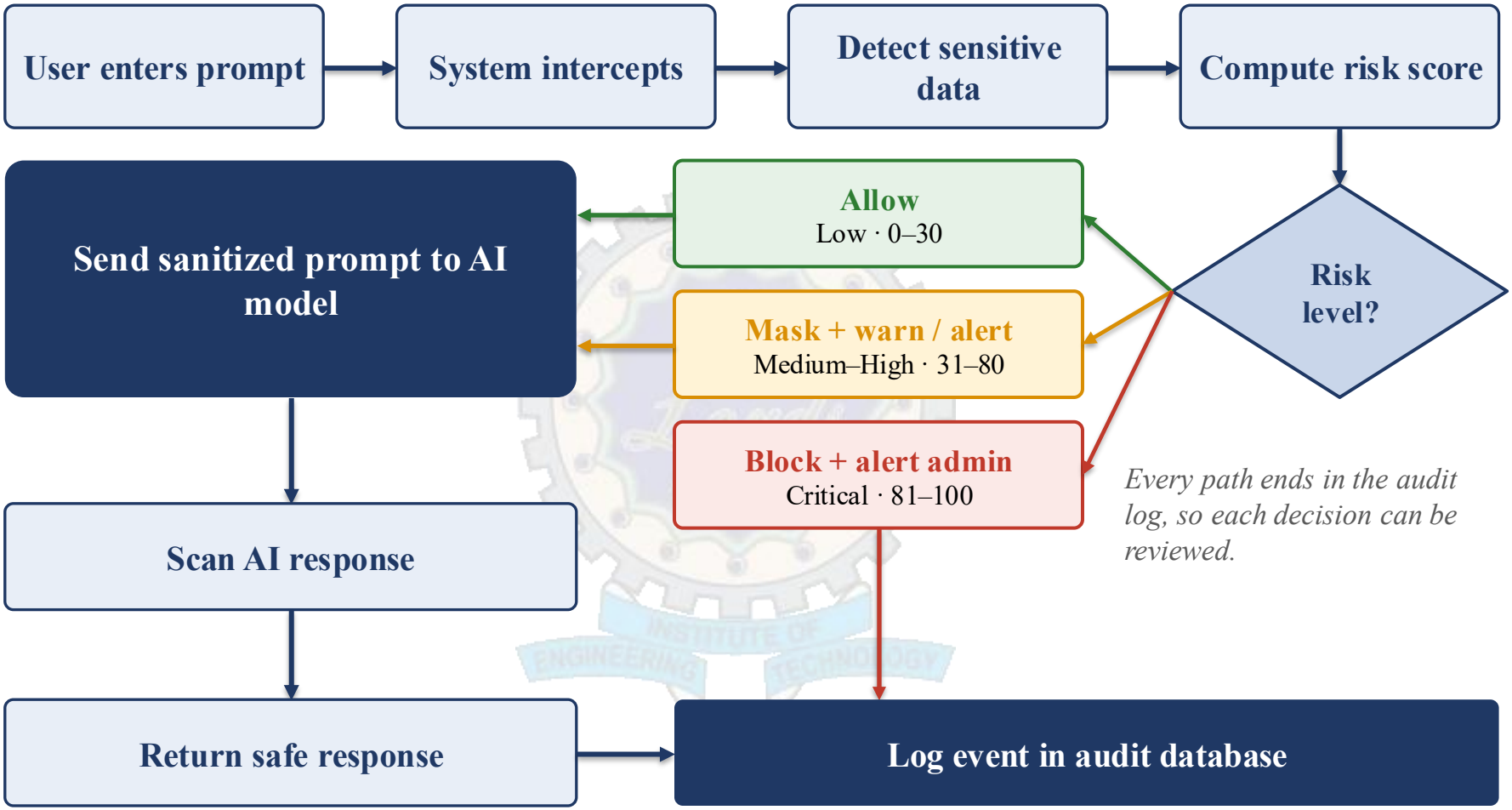
- OS: Windows 10/11 or Ubuntu 22.04
- Python 3.10+, Node.js
- spaCy, Transformers, scikit-learn, Presidio
- FastAPI, PostgreSQL, Docker
- Chrome / Edge, VS Code, Git

System Design: Architecture

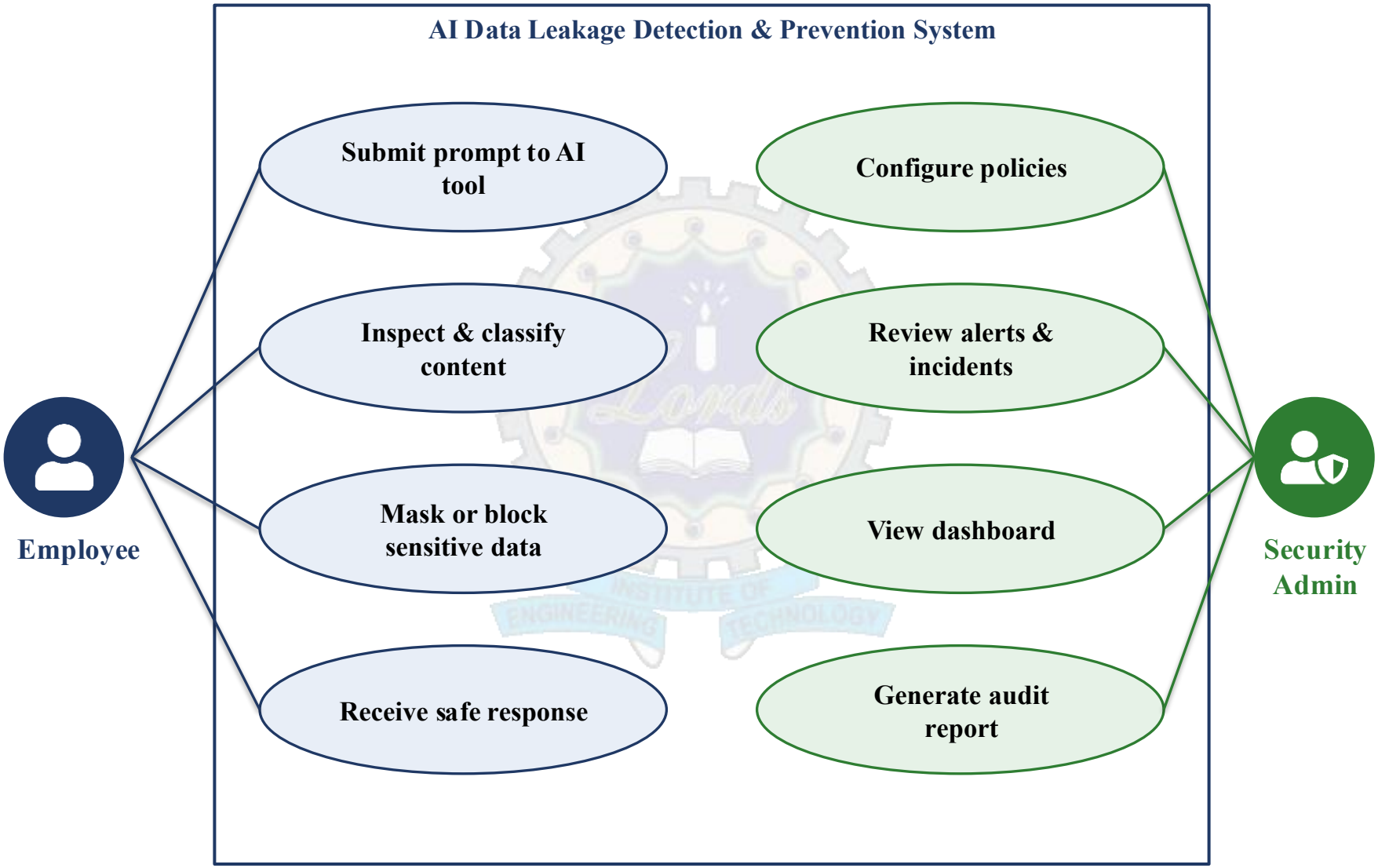


Responses return through the same pipeline: the AI reply is scanned before it reaches the user.

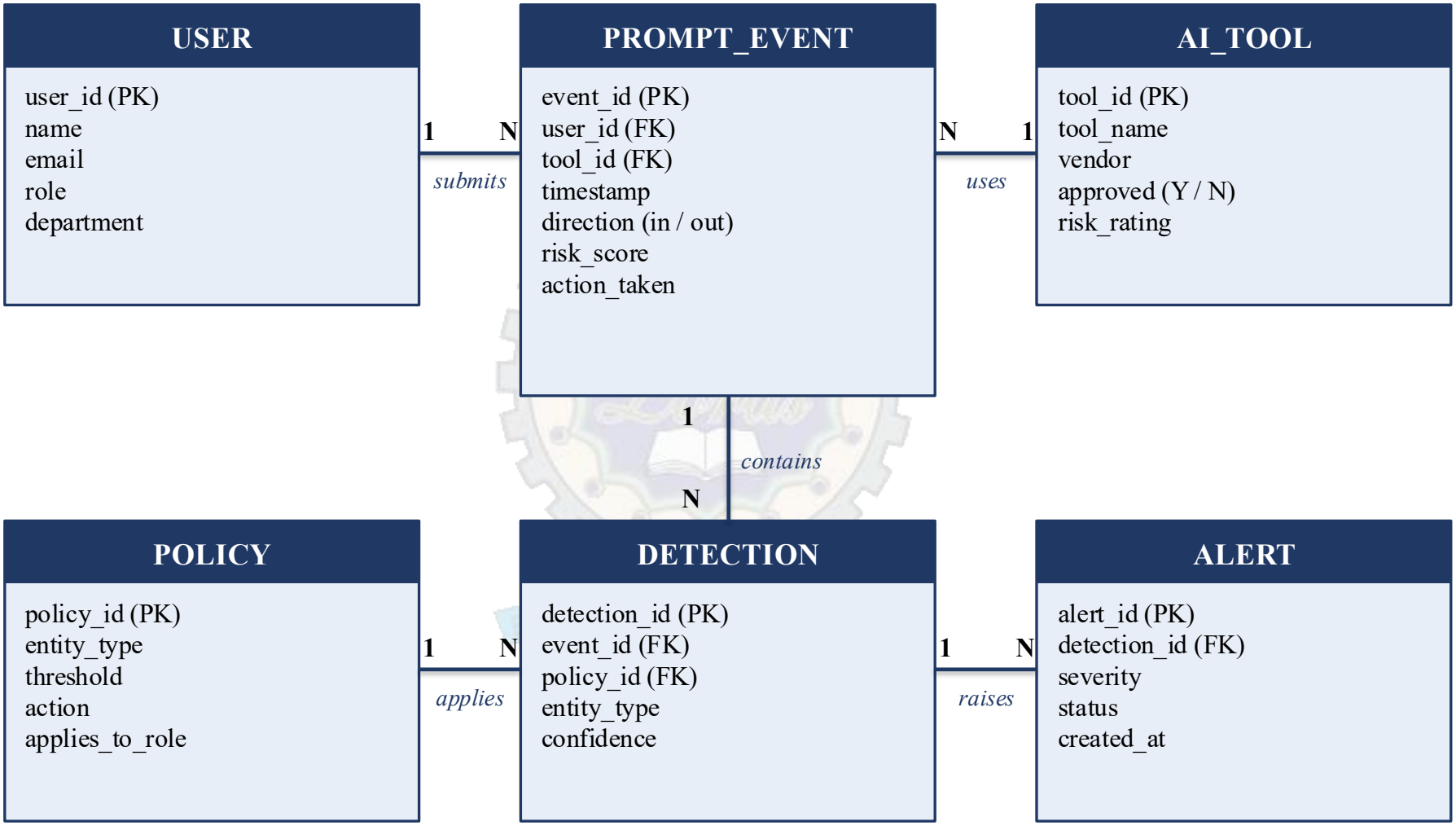
System Design: Workflow



System Design: Use Cases



System Design: ER Diagram



Implementation: Methodology

LORDS Institute of Engineering & Technology
MUSLIM MINORITY INSTITUTION
(UGC Autonomous Institution)
Accredited by NBA, Accredited 'A' Grade by NAAC

1 Collect Data

- Synthetic Indian-enterprise prompts
- Public sets: Enron, AI4Privacy
- No real personal data

2 Preprocess

- Clean and tokenize text
- Label entities and risk levels
- Train / validation / test split

3 Build Models

- Regex + Verhoeff checksum
- NER (spaCy / transformer)
- DistilBERT classifier

4 Integrate

- FastAPI gateway
- Browser extension
- Policy engine + dashboard

5 Evaluate

- Precision, recall, F1
- Latency per prompt
- Compare with Presidio baseline

Implementation: Modules

LORDS Institute of Engineering & Technology
MUSLIM MINORITY INSTITUTION
(UGC Autonomous Institution)
Accredited by NBA, Accredited 'A' Grade by NAAC

Data Interceptor

Captures prompts, uploads and AI responses at the browser or gateway.

Sensitive Data Detector

Finds PII, credentials, source code and financial data.

Risk Scorer

Scores each event 0–100 from data type, volume and destination.

Policy Engine

Applies organization rules per role, tool and data category.

Prevention Module

Masks, tokenizes, blocks or warns before data leaves.

Dashboard & Audit

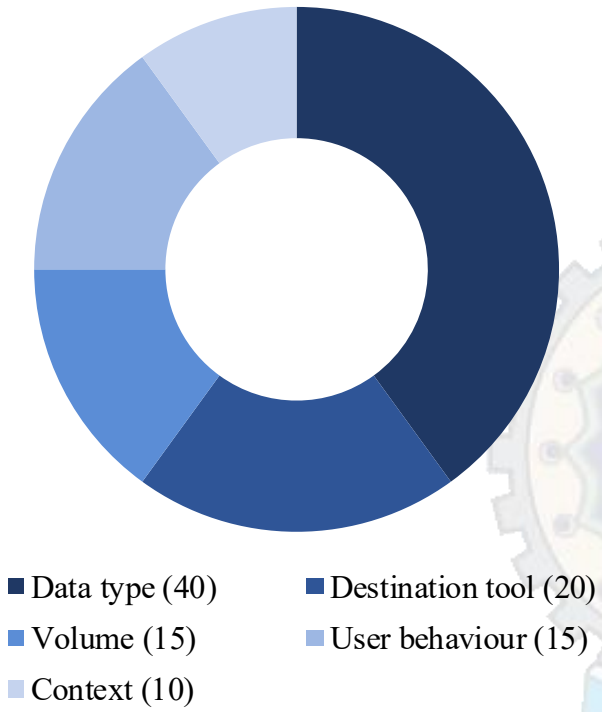
Alerts, incident history and DPDP-oriented reports.

Technology & Algorithms

Layer	Technology Used
Language	Python 3.10+
NLP / ML	spaCy, Hugging Face, scikit-learn
PII baseline	Microsoft Presidio
Backend	FastAPI
Frontend	React / Streamlit
Database	PostgreSQL
Interception	Chrome extension, proxy
Deployment	Docker (cloud or on-premise)

Algorithms Used
• Regex + Verhoeff checksum (Aadhaar) • NER with spaCy / transformers • DistilBERT sensitivity classifier • Embedding similarity for confidential documents • Isolation Forest for abnormal usage • Weighted risk scoring

Implementation: Risk Scoring



0–30 LOW
Action: Allow

31–60 MEDIUM
Action: Mask + warn user

61–80 HIGH
Action: Mask + alert admin

81–100 CRITICAL
Action: Block + alert

Example: Aadhaar + PAN pasted into an unapproved tool

40 + 10 + 20 + 10 + 8 = 88 → CRITICAL → blocked and admin alerted

Weights are initial values and will be tuned during evaluation.

Dataset & Evaluation Plan

Synthetic Indian-enterprise prompts (~10,000, labelled) built with Faker and valid-format Aadhaar / PAN / UPI

Public text: Enron emails and the AI4Privacy PII set

CERT Insider Threat data for the usage-anomaly model

No real personal data is used anywhere

Metric	Planned target
Recall, structured IDs	≥ 99%
F1, contextual entities	≥ 0.90
Added latency per prompt	< 200 ms
False-positive rate	< 5%

Targets are goals to be validated.

Baselines: Presidio default recognizers and a regex-only detector.

Results: Expected Output

Illustrative example of designed behaviour, not measured results

Original prompt (synthetic)

Summarise this loan file: Rahul Sharma, Aadhaar 2345 6789 0123, PAN ABCDE1234F, mobile 9876543210.

After protection

Summarise this loan file: [PERSON_1], Aadhaar [AADHAAR_1], PAN [PAN_1], mobile [MOBILE_1].

Risk 72 · HIGH → Mask + alert admin · placeholders restored in the reply

Planned dashboard views

- **Incidents by category**
- **Risk trend**
- **Users & AI tools**
- **Audit report export**

Results: Work Plan

LORDS Institute of Engineering & Technology
MUSLIM MINORITY INSTITUTION
(UGC Autonomous Institution)
Accredited by NBA, Accredited 'A' Grade by NAAC

Phase 1 · Review 1 | **Phase 2** | **Phase 3** | **Phase 4**

Study & Design

- Literature survey
- Research gap
- Architecture and design

Prototype

- Regex + checksum detectors
- NER and masking
- Risk scorer

Integration

- FastAPI gateway
- Browser extension
- Policy engine, dashboard

Evaluate & Report

- Test on dataset
- Compare with baselines
- Final report and demo

Conclusion

- AI tools open a new, fast-growing data-leakage channel
- Surveyed 2025–26 work leaves five clear gaps
- We propose a tiered, India-aware, risk-scored middleware



Next step

Build the detection prototype and evaluate it against baselines.

References (1/2)

[1] P. Desai, L. Tang, Y. Meng, Z. Xi, “SafeGPT: Preventing Data Leakage and Unethical Outputs in Enterprise LLM Use,” arXiv:2601.06366, Jan. 2026.

[2] F. Panebianco et al., “LeakSealer: A Semisupervised Defense for LLMs Against Prompt Injection and Leakage Attacks,” arXiv:2508.00602, Aug. 2025.

[3] “Safety Nudges: User-Facing Interventions for Real-Time AI Risk Awareness,” arXiv:2609.26865, 2026.

[4] H. Rajgarhia et al., “An Evaluation Study of Hybrid Methods for Multilingual PII Detection,” arXiv:2510.07551, 2025.

[5] “A Comparative Study of Light-weight Language Models for PII Masking and their Deployment for Real Conversational Texts,” arXiv:2512.18608, 2025.

[6] “Operationalizing Data Minimization for Privacy-Preserving LLM Prompting,” arXiv:2510.03662, 2025.

[7] “SurrogateShield: Beyond Redaction for High-Utility, Privacy-Preserving LLM Interactions,” arXiv:2606.29567, 2026.

[8] “Multi-Stage Prompt Inference Attacks on Enterprise LLM Systems,” arXiv:2507.15613, Jul. 2025.

[9] “Understanding and Mitigating Prompt Leaking Attacks in Real-World LLM-Based Applications,” arXiv:2606.18673, 2026.

[10] “ISACL: Internal State Analyzer for Copyrighted Training Data Leakage,” arXiv:2508.17767, Aug. 2025.

References (2/2)

[11] Harmonic Security, “What 22 Million Enterprise AI Prompts Reveal About Shadow AI in 2025,” Jan. 15, 2026.

[12] Cloud Security Alliance AI Safety Initiative, “Shadow AI Apps: The Enterprise Attack Surface That Outpaces Monitoring,” v1.0, May 30, 2026.

[13] IBM Security and Ponemon Institute, “Cost of a Data Breach Report 2025.”

[14] “kavach-pii: Detect, mask and restore Indian PII before it reaches an LLM,” Python Package Index.

[15] “Indian-PII Shield,” open-source privacy proxy, GitHub (aiwithrajan/indian-pii-shield).

[16] Government of India, “The Digital Personal Data Protection Act, 2023.”

[17] D. Ruiz, L. Luceri, E. Ferrara, “Agent Mosaic: Recognizing Confidentiality Leaks in Agentic LLM Systems,” arXiv:2610.30418, Oct. 2026.

[18] H. García Cuesta, P. Mateo Torrejón, A. Sánchez-Macián, “Multi-Agent Firewall Architecture for Privacy Protection of Sensitive Data in Interactions with Language Models,” arXiv:2607.08282, Jul. 2026.

[19] R. Tapwal, A. Kumar, C. Maple, “PRISM: Generation-Time Detection and Mitigation of Secret Leakage in Multi-Agent LLM Pipelines,” arXiv:2605.10614, May 2026.

[20] C.-Y. Kao et al., “You Told Me to Do It: Measuring Instructional Text-induced Private Data Leakage in LLM Agents,” arXiv:2603.11862, Mar. 2026.

LORDS
Institute of Engineering & Technology
MUSLIM MINORITY INSTITUTION
(UGC Autonomous Institution)
Accredited by NBA, Accredited 'A' Grade by NAAC

THANK YOU

Questions?

AI Data Leakage Detection & Prevention System